



INCIDENT RESPONSE REPORT

Technical Report & Documentation

Intern Name: Arsalan Rasool Rather

Organization: CyArt

Program: Red Teaming Internship

Week: Week 2



1. Executive Summary

On 14 May 2025 at approximately 09:17 IST, CyArt's security monitoring systems detected a targeted phishing campaign directed at employees within the Finance and HR departments. The attacker distributed a convincing spear-phishing email impersonating the organization's IT helpdesk, prompting recipients to click a malicious link and enter their corporate credentials on a spoofed login portal.

Three employees clicked the malicious link, and one employee (from the Finance department) entered their credentials before the link was quarantined. The compromised account was immediately isolated, credentials were reset, and no lateral movement or data exfiltration was confirmed. The incident was fully contained within 4 hours and 22 minutes of initial detection.

Severity	Impact	Accounts Compromised	Time to Contain
HIGH	Finance / HR	1 Confirmed	4h 22m

1.1 Key Findings

- A spear-phishing email bypassed existing email gateway filters due to a legitimate-looking sender domain (it-helpdesk@cyart-support[.]com).
- The malicious URL hosted a pixel-perfect clone of the CyArt internal portal (hosted on a compromised WordPress site).
- Credential theft was confirmed for one Finance department employee account.
- No evidence of lateral movement, privilege escalation, or data exfiltration was found.
- Multi-Factor Authentication (MFA) was NOT enabled on the compromised account — a critical gap identified.

1.2 Immediate Actions Taken

- Compromised user account disabled within 8 minutes of confirmation.
- Malicious URL added to enterprise DNS blocklist and email gateway deny-list.
- All three employees who clicked the link were interviewed and their systems were forensically scanned.
- Password reset enforced organization-wide as a precautionary measure.



2. Incident Details

Incident ID	INC-2025-0042
Incident Title	Spear-Phishing Campaign Targeting Finance & HR
Date Detected	14 May 2025 09:17 IST
Date Reported	14 May 2025 09:31 IST
Date Resolved	14 May 2025 13:39 IST
Reported By	SIEM Alert (Darktrace) + User Report
Assigned To	Arsalan Rasool Rather, Red Team Intern
Incident Handler	IR Lead — CyArt SOC Team
Affected Systems	Corporate Email, Internal Web Portal
Affected Users	3 clicked link; 1 credentials confirmed compromised
Attack Vector	Email Phishing (Spear-Phishing)
Attacker TTPs	T1566.001 (Spearphishing Link), T1078 (Valid Accounts)
CVSS Score (approx.)	7.5 — High

2.1 Attack Description

The attacker crafted a highly targeted spear-phishing email that appeared to originate from the CyArt IT Helpdesk. The email warned recipients that their VPN access would be revoked within 24 hours unless they re-authenticated through a provided link. This social engineering tactic created urgency and exploited trust in IT communications.

The phishing link directed victims to a cloned login portal hosted at:

```
hxxps://cyart-portal[.]it-helpdesk[.]support/vpn-auth (DEFANGED)
```

Upon entering credentials, the victim was redirected to the legitimate CyArt portal to avoid suspicion. Stolen credentials were exfiltrated to an attacker-controlled server via HTTP POST.



2.2 Phishing Email Indicators

Sender Address	it-helpdesk@cyart-support[.]com (spoofed)
Subject Line	"[URGENT] VPN Re-Authentication Required — Action Needed"
Malicious URL	hxxps://cyart-portal[.]it-helpdesk[.]support/vpn-auth
Email Header Anomaly	SPF: FAIL DKIM: FAIL DMARC: none
Payload Type	Credential Harvesting Page
C2 Server	185[.]220[.]101[.]47 (Tor exit node)



3. Incident Timeline

The following table documents the full chronological sequence of events from initial delivery of the phishing email through to resolution and post-incident review, mapped to the SANS IR phases.

Date/Time	Phase	Event / Action
14 May 08:52	Pre-Incident	Attacker sends phishing emails to 47 Finance and HR employees from spoofed domain.
14 May 09:03	Pre-Incident	First employee (User A) clicks malicious link. Credential entry not confirmed at this stage.
14 May 09:11	Pre-Incident	Second employee (User B) clicks link. No credentials entered.
14 May 09:17	Detection	Darktrace SIEM triggers alert: 'Unusual external domain login attempt from corporate IP'.
14 May 09:19	Detection	Email gateway logs flagged. Security analyst begins triage.
14 May 09:24	Detection	Third employee (User C — Finance) clicks link and enters credentials. POST request captured by proxy logs.
14 May 09:31	Detection	SOC confirms phishing campaign. Incident INC-2025-0042 opened. IR team engaged.
14 May 09:39	Containment	Malicious URL added to DNS blocklist and email gateway deny-list.
14 May 09:44	Containment	Phishing email quarantined and purged from all 47 recipient mailboxes via M365 admin.
14 May 09:52	Containment	User C's account disabled pending investigation. User notified.
14 May 10:15	Containment	Forensic scans initiated on workstations of all three users who clicked the link.
14 May 10:40	Eradication	Forensic scans return clean — no malware, keyloggers, or persistence mechanisms found.
14 May 11:05	Eradication	C2 IP (185[.]220[.]101[.]47) blocked at perimeter firewall.
14 May 11:30	Eradication	Active sessions for User C revoked across all systems (SSO, VPN, M365).
14 May 12:00	Eradication	Password reset enforced organization-wide as precaution. MFA enrollment initiated.
14 May 12:45	Recovery	User C's account re-enabled with new credentials and MFA enforced.



14 May 13:00	Recovery	All affected systems confirmed clean. Normal operations resumed.
14 May 13:39	Recovery	Incident declared contained. Monitoring elevated for 72 hours.
15 May 10:00	Post-Incident	Lessons Learned meeting held with SOC, IT, and HR departments.
16 May 09:00	Post-Incident	This Incident Response Report finalized and submitted.

4. Technical Analysis

4.1 Attack Chain (MITRE ATT&CK Mapping)

Stage	Tactic	Technique ID	Description
1	Initial Access	T1566.001	Spearphishing Link sent via spoofed email address
2	Credential Access	T1056.003	Credential entered on attacker-controlled web form
3	Exfiltration	T1041	Credentials exfiltrated via HTTP POST to C2 server
4	(Prevented)	T1078	Valid Accounts — attacker attempted login before account was disabled

4.2 Indicators of Compromise (IOCs)

IOC Type	Value
Sender Domain	cyart-support[.]com
Phishing URL	hxxps://cyart-portal[.]it-helpdesk[.]support/vpn-auth
C2 IP Address	185[.]220[.]101[.]47
Email Subject	"[URGENT] VPN Re-Authentication Required — Action Needed"
URL SHA256 Hash	a3f8c2d1e9b7...4f2a (defanged — see full IOC list in Appendix)
Phishing Page IP	91[.]108[.]56[.]201 (compromised WP host)



5. Containment, Eradication & Recovery

5.1 Containment Actions

- Malicious URL and sender domain added to email gateway deny-list (09:39 IST).
- Phishing emails purged from all 47 recipient inboxes using M365 Compliance Center Content Search.
- Compromised user account (User C) immediately disabled to prevent unauthorized access.
- C2 IP address blocked at the perimeter firewall (Palo Alto NGFW).
- All active SSO, VPN, and M365 sessions for User C were revoked.

5.2 Eradication Actions

- Full forensic disk imaging and scan performed on three affected workstations using Autopsy and ClamAV — no malware found.
- Email headers analyzed to identify and block the spoofed domain at DNS level.
- Attacker's C2 server IP added to Threat Intelligence Platform (TIP) for future correlation.
- Organization-wide password reset enforced; 100% completion verified within 3 hours.

5.3 Recovery Actions

- User C's account re-enabled with new strong credentials and MFA enforced (Microsoft Authenticator).
- All previously blocked legitimate access restored and tested.
- Monitoring alerts elevated for User C's account and Finance department for 72-hour window.
- All-staff security awareness notification sent explaining the phishing campaign.



6. Mitigation Steps & Recommendations

The following mitigation measures are recommended to prevent recurrence of similar incidents, mapped to priority and effort level.

Recommendation	Rationale	Priority	Effort
Enforce MFA on all corporate accounts immediately	<i>The compromised account lacked MFA — the single biggest enabler of this incident</i>	CRITICAL	Low
Deploy DMARC, DKIM, and SPF enforcement for all domains	<i>Phishing email passed without authentication checks</i>	HIGH	Medium
Implement AI-based email security (e.g., Abnormal Security)	<i>Rule-based filters missed the spoofed domain</i>	HIGH	Medium
Conduct monthly phishing simulation exercises	<i>3 of 47 users clicked the link — awareness gap identified</i>	HIGH	Low
Enable DNS filtering (e.g., Cisco Umbrella)	<i>Would have blocked the phishing URL at DNS level before page load</i>	HIGH	Low
Restrict VPN and email access from unregistered devices	<i>Prevents credential reuse from attacker-controlled machines</i>	MEDIUM	Medium
Review and update Security Awareness Training content	<i>Current training did not prevent click-through</i>	MEDIUM	Low
Implement URL sandboxing on email gateway	<i>Malicious link was not detonated/analyzed pre-delivery</i>	MEDIUM	High

7. Lessons Learned

7.1 What Worked Well

- SIEM (Darktrace) detection was fast — alert fired within 25 minutes of campaign start.
- Incident response playbook was followed effectively — containment achieved in under 1 hour.
- Email quarantine via M365 Compliance Center was efficient and complete.
- Cross-team communication between SOC, IT, and HR was smooth throughout the incident.



7.2 What Could Be Improved

- MFA was not enforced on all accounts — this is the primary gap that enabled credential theft to have impact.
- Email gateway failed to flag SPF/DKIM/DMARC failures in real-time for analyst review.
- Security awareness training had insufficient coverage of spear-phishing social engineering tactics.
- No automated account lockout triggered on failed cross-domain login attempts from User C's credentials.

7.3 Action Items

Action Item	Owner
Enable MFA for all user accounts	IT Security Team
Configure DMARC enforcement (p=reject)	Email Admin
Launch phishing simulation program	Security Awareness Team
Deploy DNS filtering solution	Network Team
Update IR playbook with MFA bypass scenarios	SOC Lead



8. Appendix

8.1 SANS IR Phase Reference

Phase 1 — Preparation	Policies, tools, training in place before incident occurs
Phase 2 — Identification	Detect and confirm the incident using logs, alerts, and triage
Phase 3 — Containment	Stop the spread — short-term and long-term containment actions
Phase 4 — Eradication	Remove the root cause, malware, and attacker access
Phase 5 — Recovery	Restore systems, verify integrity, monitor for recurrence
Phase 6 — Lessons Learned	Post-incident review, documentation, and improvement actions

8.2 Evidence & Artefacts

- Email gateway logs: /logs/email/20250514_phishing_campaign.log
- SIEM alert export: INC-2025-0042_darktrace_alert.json
- Forensic disk image hashes: forensics/userC_disk_sha256.txt
- Proxy logs showing credential POST: /logs/proxy/20250514_0924_userC.log
- M365 Content Search export: compliance/INC-2025-0042_quarantine_report.csv
- Phishing URL screenshot (defanged): evidence/phishing_page_screenshot.png

8.3 Report Sign-Off

Prepared By	Arsalan Rasool Rather Red Teaming Intern
Reviewed By	[IR Lead Name] CyArt SOC
Approved By	[CISO / Manager Name] CyArt
Report Version	1.0 — Final
Date Submitted	16 May 2025